

TCS3351 CRYPTOGRAPHY AND DATA SECURITY
Tutorial 11 - Entity Authentication/Digital Signature Schemes/Key
Management and Distribution

1. Briefly explain how the hash function can be used for fixed password authentication.

Answer:

Fixed password authentication uses the same fixed password repeatedly for every access. The hash function can be used to create and store the hash of the password in the password file.

When a user sends the ID and the password, the system will create a hash of the sent password and compares it with the hash value that is stored in the password file. If such comparison is matched, the user is granted access, otherwise, the access is denied.

2. Briefly explain the approach of Leslie Lamport for one-time password authentication.

Answer:

In the one-time password authentication devised by Leslie Lamport, the user and the system create sequential updated password using a hash function. In this approach, the user and the system firstly agree upon an original password, says P_0 and a counter n . Next, the system computes $h^n(P_0)$, where h^n denotes the applied hash function for n times. Mathematically,

$$h^n(P_0) = h(h^{n-1}(P_0)) = h(h(h^{n-2}(P_0))) = h(h(h(\dots(h(P_0) \dots))).$$

The system stores the identity of the user, the value of n , and the value of $h^n(P_0)$ as 3-tuple $\{ID, n, h^n(P_0)\}$. When the system receives the response $h^{n-1}(P_0)$ of the user, it firstly applies hash function to verify if $h(h^{n-1}(P_0)) = h^n(P_0)$ matches the value stored in the entry. If it does, the user is then granted access, and denied otherwise. The system next decreases the counter by 1 and replaces the $h^n(P_0)$ value with $h^{n-1}(P_0)$.

For the 2nd access, the hash value received from the user will be $h^{n-2}(P_0)$, and the system now verifies whether $h(h^{n-2}(P_0)) = h^{n-1}(P_0)$. If it does, the user is granted access, and denied otherwise. The exact procedure is repeated each time with the counter decreases by 1 until it reaches 0, where the user can no longer access the system.

3. Explain the generic model on the process of constructing and verifying digital signatures with the help of public key cryptography.

Answer:

Suppose a user (Sender A) wants to send a message M to another user (Receiver). Sender will first generate a hash value $h = H(M)$ using some strong hash functions (agreed upon communication) which will serves as message digest. The message digest h together with sender A's private key will input into a digital signature generation algorithm, producing a short block which functions as a digital signature $\sigma = \text{Sig}(\text{Prv}_A, h)$. Finally, $(M \parallel \sigma)$ is sent to receiver.

When receiver receives the message-signature pair $(M \parallel \sigma)$, he will first extract M from σ , and next compute the hash value $H(M) = h$ using the identical hash function. The output hashed value h is then input into the digital signature verification algorithm together with sender A 's public key and the digital signature to verify whether $\text{Vrfy}(\text{Pub}_A, \sigma) = h$. If the verification outputs a match, then the receiver is assured that it is indeed the sender who signs the message.

The alteration is impossible in this scenario, since sender A possesses the private key, only he can generate the valid signature corresponding to the message sent. Mathematically $\sigma = \text{Sig}(\text{Prv}_A, H(M))$. An attacker will need to break sender A 's private to alter and sign the message correctly.

4. Differentiate between the RSA and DSA approaches of creating and verifying digital signatures.

Answer:

RSA Approach	DSA Approach
The message M is hashed into a hash code (message digest) $h = H(M)$ of a fixed length.	The message M is hashed into a hash code (message digest) $h = H(M)$ of a fixed length.
Next, the hash code h is signed using sender A's private key Prv_A to produce a digital signature $\sigma = \text{Sig}(\text{Prv}_A, h)$	Next, the hash code h is signed using sender's private key Prv_A, a random number k, and a group's public parameters Pub_G to produce a pair of digital signatures $(r, s) = \text{Sig}(\text{Prv}_A, \text{Pub}_G, k, h)$
The message M is then concatenated with the digital signature s and sent to receiver as $(M \parallel \sigma)$.	The message M is then concatenated with the digital signature pair (r, s) and sent to receiver as $(M \parallel (r, s))$.
Receiver receives $(M \parallel \sigma)$, extract M and computes $h = H(M)$.	Receiver receives $(M \parallel (r, s))$, extract M and computes $h = H(M)$.
Next, receiver verifies whether $h' = \text{Vrfy}(\text{Pub}_A, \sigma)$ using sender A's public key Pub_A. If $h' = h$ (that is, identical), then the signature is accepted as valid.	Next, receiver verifies whether $r' = \text{Vrfy}(\text{Pub}_A, \text{Pub}_G, h, s)$ using sender A's public key Pub_A group's public parameter Pub_G. If $r' = r$ (that is, identical), then the signature is accepted as valid.

5. Define Kerberos and name the servers involved in Kerberos protocol. List the duties of Public Key Infrastructure (PKI).

Answer:

Kerberos is an **authentication protocol**, and at the same time a **Key Distribution Center (KDC)**. It makes use of a trusted third party (the authentication service) that enables clients and serves to established authenticated communication. The Kerberos protocol consists of three servers, that are the Authentication server (AS), the Ticket-Granting Server (TGS), and the real server that provides services for the users.

Duties of Public Key Infrastructure:

- a) To issue, renew, and revoke certificates
- b) To store and update keys
- c) To provide services and other protocols
- d) To provide access control

References:

1. William Stallings, “Cryptography and Network Security – Principles and Practice”, Seventh Edition, Prentice Hall, 2017
2. Forouzan, B. A. & Mukhopadhyay, D. (2015). Cryptography & Network Security (3rd ed.). McGraw-Hill.